**Name: Shreyas B Patil SRN: PES2UG24CS488 SEC: H LAB: 5**

## PART 1: BEOFRE FIXING THE ERRORS

### A) bandit report:

```
Run started:2026-10-14 06:34:12.557980+00:00

Test results:
>> Issue: [B110:try_except_pass] Try, Except, Pass detected.
   Severity: Low   Confidence: High
   CWE: CWE-703 (https://cwe.mitre.org/data/definitions/703.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b110_try_except_pass.html
   Location: .\restaurant_order_system.py:26:4
25              del orders[table_id]
26          except:
27              pass
28

--------------------------------------------------
>> Issue: [B307:blacklist] Use of possibly insecure function - consider using safer ast.literal_eval.
   Severity: Medium   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b307-eval
   Location: .\restaurant_order_system.py:42:16
41          base_bill = orders[table_id]["bill"]
42          net_total = eval(promo_expr)
43          return net_total

--------------------------------------------------
>> Issue: [B324:hashlib] Use of weak MD5 hash for security. Consider usedforsecurity=False
   Severity: High   Confidence: High
   CWE: CWE-327 (https://cwe.mitre.org/data/definitions/327.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b324_hashlib.html
   Location: .\restaurant_order_system.py:47:11
46      def generate_ticket_hash(table_id):
47          return hashlib.md5(table_id.encode()).hexdigest()
48

--------------------------------------------------
```

```
--------------------------------------------------
>> Issue: [B311:blacklist] Standard pseudo-random generators are not suitable for security/cryptographic purposes.
   Severity: Low   Confidence: High
   CWE: CWE-330 (https://cwe.mitre.org/data/definitions/330.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/blacklists/blacklist_calls.html#b311-random
   Location: .\restaurant_order_system.py:51:11
50      def generate_pos_pin():
51          return random.randint(1000, 9999)
52

--------------------------------------------------
>> Issue: [B605:start_process_with_a_shell] Starting a process with a shell, possible injection detected, security issue.
   Severity: High   Confidence: High
   CWE: CWE-78 (https://cwe.mitre.org/data/definitions/78.html)
   More Info: https://bandit.readthedocs.io/en/1.9.4/plugins/b605_start_process_with_a_shell.html
   Location: .\restaurant_order_system.py:58:4
57          f.close()
58          os.system("echo Ticket sent to kitchen printer: " + filename)
59

--------------------------------------------------

Code scanned:
        Total lines of code: 61
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 2
                Medium: 1
                High: 2
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 5
Files skipped (0):
```

### B) pylint report:

```
************* Module restaurant_order_system
restaurant_order_system.py:18:0: C0301: Line too long (110/100) (line-too-long)
restaurant_order_system.py:83:0: C0304: Final newline missing (missing-final-newline)
restaurant_order_system.py:15:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system.py:15:0: C0103: Function name "placeTableOrder" doesn't conform to snake_case naming style (invalid-name)
restaurant_order_system.py:15:0: W0102: Dangerous default value [] as argument (dangerous-default-value)
restaurant_order_system.py:19:21: C0209: Formatting a regular string which could be an f-string (consider-using-f-string)
restaurant_order_system.py:23:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system.py:23:0: C0103: Function name "voidTableOrder" doesn't conform to snake_case naming style (invalid-name)
restaurant_order_system.py:26:4: W0702: No exception type(s) specified (bare-except)
restaurant_order_system.py:30:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system.py:30:0: C0103: Function name "checkTableStatus" doesn't conform to snake_case naming style (invalid-name)
restaurant_order_system.py:32:7: C0121: Comparison 'orders.get(table_id) == None' should be 'orders.get(table_id) is None' (singleton-comparison)
restaurant_order_system.py:34:4: R1703: The if statement can be replaced with 'return bool(test)' (simplifiable-if-statement)
restaurant_order_system.py:34:4: R1705: Unnecessary "else" after "return", remove the "else" and de-indent the code inside it (no-else-return)
restaurant_order_system.py:31:4: W0612: Unused variable 'service_tax' (unused-variable)
restaurant_order_system.py:40:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system.py:40:0: C0103: Function name "calculateDiscountedBill" doesn't conform to snake_case naming style (invalid-name)
restaurant_order_system.py:42:16: W0123: Use of eval (eval-used)
restaurant_order_system.py:41:4: W0612: Unused variable 'base_bill' (unused-variable)
restaurant_order_system.py:46:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system.py:50:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system.py:54:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system.py:55:8: W1514: Using open without explicitly specifying an encoding (unspecified-encoding)
restaurant_order_system.py:55:8: R1732: Consider using 'with' for resource-allocating operations (consider-using-with)
restaurant_order_system.py:61:0: C0116: Missing function or method docstring (missing-function-docstring)
restaurant_order_system.py:61:24: W0621: Redefining name 'orders' from outer scope (line 8) (redefined-outer-name)
restaurant_order_system.py:63:8: W0612: Unused variable 't' (unused-variable)
restaurant_order_system.py:6:0: W0611: Unused import math (unused-import)

-----------------------------------
Your code has been rated at 4.81/10
```

### C) flake8 report

```
restaurant_order_system.py:6:1: F401 'math' imported but unused
restaurant_order_system.py:18:80: E501 line too long (110 > 79 characters)
restaurant_order_system.py:19:80: E501 line too long (85 > 79 characters)
restaurant_order_system.py:26:5: E722 do not use bare 'except'
restaurant_order_system.py:31:5: F841 local variable 'service_tax' is assigned to but never used
restaurant_order_system.py:32:29: E711 comparison to None should be 'if cond is None:'
restaurant_order_system.py:41:5: F841 local variable 'base_bill' is assigned to but never used
restaurant_order_system.py:75:80: E501 line too long (80 > 79 characters)
restaurant_order_system.py:83:7: W292 no newline at end of file
```

### PART 2: SUMMARY OF ERRORS:

| Issue | Type | Line(s) | Description | Fix approach |
|---|---|---|---|---|
| Mutable default argument | Bug | 15 | A shared list is used as the default argument. | Replace [] with None. |
| Bare exception | Bug | 24–27 | Exceptions are silently ignored. | Handle KeyError explicitly. |
| Unsafe eval() | Security | 42 | Executes potentially malicious Python expressions. | Replace with safe discount calculation. |
| Weak MD5 hashing | Security | 47 | MD5 is unsuitable for security-sensitive hashing. | Use SHA-256. |
| Insecure random number | Security | 51 | random.randint() is unsuitable for generating security-sensitive PINs. | Use secrets.randbelow(). |
| Shell command injection | Security | 58 | os.system() executes a shell command containing a filename. | Replace shell command with print(). |
| Unused import | Code quality | 6 | The math module is never used. | Remove the import. |
| Unused variables | Code quality | 31, 41 | Variables are assigned but never used. | Remove or use them appropriately. |
| Incorrect None comparison | Style | 32 | Uses == None instead of is None. | Use is None. |
| Invalid function naming | Style | 15, 23, 30, 40 | Function names do not follow snake_case. | Rename functions. |

| | | | | |
|---|---|---|---|---|
| Missing docstrings | Documentation | Multiple | Functions lack descriptions. | Add meaningful docstrings. |
| Long lines | Formatting | 18, 19, 75 | Lines exceed Flake8's 79-character limit. | Split long statements across lines. |
| Missing final newline | Formatting | 83 | File does not end with a newline. | Add a newline. |

**PART 3: AFTER FIXING THE ERRORS**

**A) bandit report:**

```
Run started:2026-10-14 13:13:16.194308+00:00

Test results:
        No issues identified.

Code scanned:
        Total lines of code: 71
        Total lines skipped (#nosec): 0
        Total potential issues skipped due to specifically being disabled (e.g., #nosec BXXX): 0

Run metrics:
        Total issues (by severity):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
        Total issues (by confidence):
                Undefined: 0
                Low: 0
                Medium: 0
                High: 0
Files skipped (0):
```

**B) pylint report:**

```

--------------------------------------------------------------------
Your code has been rated at 10.00/10 (previous run: 10.00/10, +0.00)
```

**C) flake8 report: pls note that the original output for flake8 was empty. To make it meaningful to evaluator we added a extra line as shown in echo screenshot**

```
Flake8 analysis completed: No issues found.
```

```
C:\Users\shreyas-pc\Projects\SE_lab_CS488_H\Lab5>echo Flake8 analysis completed: No issues found. > after\flake8_report.
txt
```

**Commit history:**

```
C:\Users\shreyas-pc\Projects\SE_lab_CS488_H\Lab5>git log --oneline -4
59532cb (HEAD -> main, origin/main, origin/lab5-bandit-fixes, origin/HEAD, lab5-bandit-fixes) Lab5: Add Flake8 verificat
ion and static analysis reports
28bc310 Lab5: Fix Pylint code quality issues
8980fb6 Lab5: Fix Bandit security vulnerabilities
25fd0ab Lab5: Add original restaurant order system
```